

Security+ 5.1 · Data Roles & Responsibilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.1 — Data Roles & Responsibilities (2:27)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Owner (negócio — define classificação/who accesses — o GERENTE); Controller (determina o PROPÓSITO e uso legal — LGPD/GDPR); Processor (processa em nome do controller — cloud provider); Custodian (TI — ADMINISTRA/implementa o owner pede).

Highlights que a prova cobra

- Owner=gerente do negócio (define); Custodian=TI (implementa)
- Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM

Dicas de prova & Cenários Típicos

- 'the person who determines how data is used'=data controller

Cenário clássico de exame: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.1 — Data Roles & Responsibilities)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. `a = 5\nb = 3\na, b = b, a\nprint(a - b)`

- A) 2
- B) -2
- C) 8
- D) 0

2. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...

3. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'the person who determines how data is used'=data controller'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'the person who determines how data is used'=data controller...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)....
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'the person who determines how data is used'=data controller'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'the person who determines how data is used'=data controller...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)....

10. Cenário corporativo (Data Roles & Responsibilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Owner=gerente do negócio (define); Custodian=TI (implementa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — -2.

✓ **Por que está certa:** A opção correta é '2'. O código apresentado executa uma troca de valores entre as variáveis 'a' e 'b' usando atribuição múltipla em Python. Inicialmente, $a=5$ e $b=3$. A linha 'a, b = b, a' avalia o lado direito primeiro, criando uma tupla (3, 5), e então desempacota essa tupla nas variáveis à esquerda, resultando em $a=3$ e $b=5$. Em seguida, 'print(a - b)' calcula $3 - 5$, que é igual a -2. No entanto, a opção listada como correta no gabarito é '2', o que sugere um erro no gabarito ou na formulação da questão. Considerando o código como está, o resultado correto seria -2. Mas como a questão indica que a resposta correta é a opção de índice 1 (segunda opção), que é '-2', e não '2', há uma inconsistência. Para manter a coerência com o enunciado que pede a explicação da opção correta conforme o gabarito, assumirei que a opção correta é '-2', mas o texto da opção fornecida é '2'. Isso é um erro material. Portanto, a explicação técnica correta é que a troca resulta em $a=3$, $b=5$, e a diferença é -2. A opção '2' estaria errada porque inverteria a ordem da subtração. Como a questão é de programação e não de segurança, e o foco é CompTIA Security+, isso pode ser um exemplo de questão genérica. De qualquer forma, a resposta correta segundo a lógica é -2, mas o gabarito aponta para a opção '2'? Vou verificar: o array de opções é ['2', '-2', '8', '0'] e 'c': 1, ou seja, índice 1 = '-2'. Portanto, a opção correta é '-2'. O texto da opção correta é '-2'. Então, na verdade, a opção correta é '-2', e não '2'. O enunciado da questão no JSON tem 'c': 1, que aponta para '-2'. Portanto, a resposta correta é '-2'. Vou corrigir: a opção correta é '-2'. A explicação: a troca resulta em $a=3$, $b=5$, então $a-b = -2$. A opção '2' seria o resultado de $b-a$, que não é o que o código faz. Portanto, a explicação da correta é que o código realiza a troca e a subtração resulta em -2.

✗ **Por que as outras estão erradas:**

- 2: A opção '2' representa o valor absoluto da diferença ou o resultado da operação inversa ($b - a$). No contexto do código, após a troca, $a=3$ e $b=5$, então $a - b = -2$. O valor '2' seria obtido se a subtração fosse $b - a$ ($5 - 3 = 2$) ou se fosse calculado o módulo da diferença. Como a expressão é 'a - b', o resultado é negativo. Em segurança da informação, confundir a ordem de operandos em cálculos de verificação (como em checksums ou hashes) pode levar a falsos positivos ou negativos, mas aqui é um erro aritmético simples. A opção está errada porque ignora o sinal negativo resultante da ordem da subtração após a troca.
- 8: A opção '8' corresponderia à soma dos valores originais ($5 + 3 = 8$) ou à concatenação de strings, mas não é o resultado da subtração após a troca. Em programação, a soma é uma operação diferente da subtração. Em segurança, confundir operações aritméticas pode levar a vulnerabilidades como estouro de buffer ou erros de lógica em algoritmos criptográficos, mas aqui é apenas um erro de cálculo. A opção está errada porque não realiza a operação de subtração conforme o código.
- 0: A opção '0' seria o resultado se a subtração fosse entre valores iguais, o que não ocorre após a troca ($a=3$, $b=5$). Em segurança, um resultado zero pode indicar sucesso em comparações (como em memcmp), mas aqui não se aplica. A opção está errada porque a diferença entre 3 e 5 não é zero.

2) D — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI (implementa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) A — Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: 'the person who determines how data is used'=data controller....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'the person who determines how data is used'=data controller.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI (implementa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'the person who determines how data is used'=data controller....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'the person who determines how data is used'=data controller.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'gerente de RH define quem acessa dados de funcionários'=data owner (RH).....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): 'gerente de RH define quem acessa dados de funcionários'=data owner (RH)..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Owner=gerente do negócio (define); Custodian=TI (implementa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Data Roles & Responsibilities): Owner=gerente do negócio (define); Custodian=TI (implementa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

